

ACLens: Graph-Guided Multi-Agent Framework for Access Control Vulnerability Detection in Smart Contracts

Anonymous Author(s)

Abstract

Smart contracts are immutable, self-executing programs deployed on blockchains that typically manage substantial financial assets, making them a prime target for attackers. While Access Control (AC) vulnerabilities constitute the leading cause of financial loss, identifying them is increasingly challenging as authorization logic spans multiple functions with shared state variables and diverse business rules. Existing detectors are heavily dependent on guard pattern matching or sender taint analysis, but these methods frequently prove ineffective in the context of DeFi protocols. The root cause of such vulnerabilities is rarely the absence of guard patterns, but rather the exploitable reachability of privileged operations under unintended policies.

Tackling this fundamental issue requires evaluating two distinct criteria, namely identifying which operations carry privileged effects and determining whether any feasible path can reach them in violation of the authorization policy implied by the contract's own protection patterns. In this work, we propose ACLens, a multi-agent framework guided by program graphs to conduct the analysis in two dedicated phases. The first phase performs deterministic graph analysis to pinpoint critical sinks and delineate a compact evidence boundary around them. The second phase deploys three agents to reconstruct an execution trace reaching each sink, infer the intended authorization policy from intra-contract evidence, and determine whether the reconstructed trace violates the inferred policy. On a DeFi exploit benchmark of 46 validated projects and 97 vulnerable functions, ACLens reaches 83.5% recall and 55.1% F1, outperforming the strongest baseline (i.e., ACTaint) by 46.4 points in recall and 20.0 points in F1.

Keywords

Access Control Vulnerability, Smart Contracts, Code Property Graph, Large Language Models, Multi-Agent Analysis

1 Introduction

Decentralized finance (DeFi) protocols built on smart contracts now manage billions of dollars in total value locked [2, 6]. Because these contracts are immutable once deployed, a vulnerability cannot be patched and exploitation leads to irreversible financial losses [35, 47]. Among all vulnerability classes, *access control (AC) defects* are the most costly, arising when critical operations are executed without proper authorization. In 2024, access-control exploits accounted for 75% of all crypto hacks, with roughly \$1.7 billion stolen [18]. The 2025 OWASP Smart Contract Top 10 ranks AC vulnerabilities as the number-one threat [32].

Unlike reentrancy or integer overflow, AC vulnerabilities depend on the developer's implicit intent rather than on language semantics.

A public function that modifies the owner variable, for instance, is vulnerable only if the developer intended to restrict that operation. On CVE-style benchmarks where each flaw is confined to a single function, specialized tools perform reasonably well. ACChecker [16] and ACTaint [22] achieve 80% and 93.3% recall, respectively. However, these benchmarks rarely mirror production DeFi contracts. This observation is further supported by our evaluation on a new DeFi benchmark under a strict function-level protocol (Section 4), in which the best-performing baseline reaches only 37.1% recall on confirmed exploits.

This performance gap indicates a structural limitation in existing detection methods. AC vulnerability detection begins by locating critical operations (e.g., external transfers, privileged state writes, and self-destruction), relying mostly on structural patterns. The more challenging task lies in determining whether critical operations actually lack adequate protection. Traditional tools address this challenge by verifying the presence of known guard patterns. Although some advanced systems [4, 11, 16, 21, 25] incorporate techniques such as guard pattern matching and sender taint analysis, they still validate primarily against predefined protection mechanisms. In production DeFi contracts, however, authorization logic is rarely confined to standard modifiers or recognizable patterns. It emerges from intra-contract state relationships that are distributed across multiple functions and shared state variables, making it only partially visible to pattern-based analysis.

LLM-based approaches have also been explored for AC detection [22, 23]. Applying them effectively, however, requires overcoming two obstacles inherent to AC vulnerabilities. **C1: Authorization logic is structurally indistinguishable in standard program representations.** In conventional program graphs, guards that depend on the caller are encoded identically to ordinary business predicates, and all accesses to the same indexed state variable collapse into a single abstract location regardless of their index keys. As a result, no structural signal separates an authorization check from an arithmetic bound or a balance lookup. This absence undermines the validity of any analysis relying on such representations. Besides, providing the entire contract to an LLM obscures authorization signals amidst irrelevant code [24], whereas slicing along standard dependence edges fails to preserve cross-function state relationships. In both cases, the pivotal evidence necessary for determining AC vulnerabilities is lost. **C2: Vulnerability is defined against an implicit policy specific to the contract.** Certain common vulnerabilities, such as reentrancy and integer overflow, stem from violations of language-level semantics that can be defined independently of any specific contract. AC violations, by contrast, are meaningful only relative to an authorization policy that the developer rarely specifies explicitly. Traditional detectors reduce this ambiguity to closed-world pattern matching. LLMs can

ASE '26,
2026. ACM ISBN 978-x-xxxx-xxxx-x/YYYY/MM
<https://doi.org/10.1145/nnnnnnn.nnnnnnn>

reason about open-ended policies, but without structured comparative evidence they cannot distinguish intentionally permissionless interfaces from accidentally unprotected ones.

Despite the semantic complexity of access control (AC) rules, their structural evidence can be identified through dependency relationships before any semantic interpretation is required. Building on this insight, we propose ACLens, a multi-agent framework for detecting AC vulnerabilities in smart contracts, guided by program graphs. Concretely, ACLens formulates AC detection as a two-phase process. In the first phase, Graph-Guided Structural Analysis leverages an Access Control Property Graph (ACPG) to identify critical sinks and extract a compact evidence boundary for each target function. In the second phase, Multi-Agent Security Reasoning decomposes the analysis across specialized agents: one reconstructs the execution trace leading to the sink, another infers the intended authorization policy from existing protection patterns in the contract, and a verifier determines whether the trace violates that policy. Rather than exposing each reasoning agent to the entire contract, ACLens uses dependency graphs to define a per-function evidence boundary prior to any semantic analysis. Our evaluation on a DeFi benchmark comprising 46 validated projects (Section 4) shows that this decomposition achieves 83.5% recall and 55.1% F1, surpassing the strongest specialized baseline by 46.4 in recall and 20.0 in F1 score. In summary, this work makes the following contributions.

- We propose ACLens, a multi-agent framework for AC vulnerability detection in smart contracts that combines graph-guided structural localization with multi-agent policy reasoning. To the best of our knowledge, this is the first work to leverage program graph analysis to delimit the evidence scope for each critical sink, thereby enabling more effective multi-agent reasoning for AC vulnerability detection.
- In ACLens, we design an Access Control Property Graph (ACPG) that extends standard code property graphs with caller-dependent guard semantics and cross-function state links, enabling precise sink identification and compact evidence extraction via backward slicing.
- We evaluate ACLens on a DeFi benchmark of 46 projects spanning six chains. Under a strict function-level protocol over confirmed exploit cases, ACLens achieves 83.5% recall and 55.1% F1, more than doubling the recall of the best-performing specialized baseline (37.1%) while maintaining competitive precision.

2 Motivating Example

We illustrate the limitations of existing AC detection approaches using a real-world exploit from April 2024. The target is XBridge [39], a cross-chain bridge contract deployed on Ethereum. An attacker exploited a scoping inconsistency between token registration and ownership tracking to hijack deposited liquidity.

The vulnerability. The bridge holds tokens deposited by liquidity providers. `listToken` registers a token for cross-chain bridging and records the caller as the token's owner in `_tokenOwner` (line 17). `withdrawTokens` checks this mapping and transfers funds only to the recorded owner (line 23).

```
// Chain-pair-specific token mapping
mapping(uint => mapping(uint =>
mapping(address => address))) public pairMap;
// Global token ownership (NOT chain-specific)
mapping(address => address) public _tokenOwner;

// Function A: register a cross-chain token pair
function listToken(TokenInfo memory base,
TokenInfo memory corr, bool mintable)
external payable {
require(pairMap[base.chain][corr.chain]
[base.token] == address(0), "LISTED");
pairMap[base.chain][corr.chain]
[base.token] = corr.token;
isMintable[base.chain][corr.chain]
[base.token][corr.token] = mintable;
_tokenOwner[base.token] = msg.sender;
}

// Function B: withdraw deposited liquidity
function withdrawTokens(address token,
address receiver, uint256 amount) external {
require(msg.sender == _tokenOwner[token],
"ONLY_LISTER");
IERC20(token).transfer(receiver, amount);
}
```

Figure 1: Simplified XBridge cross-chain bridge.

The bug lies in a dimensionality mismatch between two mappings. The uniqueness check on line 11 queries the three-dimensional `pairMap`, indexed by source chain, destination chain, and token address. It therefore prevents the same token from being listed twice on the *same* chain pair. The ownership assignment on line 17, however, writes to the one-dimensional `_tokenOwner`, keyed *solely* by token address with no chain-pair scoping. A token can therefore be listed on multiple chain pairs, and each listing silently overwrites its global owner. An attacker exploits this by re-listing an already-registered token on a different chain pair, hijacking its ownership entry, and draining the deposited liquidity via `withdrawTokens`. Any analysis that examines each function in isolation, or treats all accesses to `_tokenOwner` as equivalent regardless of their key structure, will miss this vulnerability. Existing tools fail for different but complementary reasons.

- **Bytecode-level taint (AChecker [16]).** AChecker performs intraprocedural `msg.sender` dependency analysis on EVM bytecode. It detects the `require(msg.sender == _tokenOwner[token])` guard in `withdrawTokens` and classifies the function as protected. Its single-function analysis scope cannot observe the cross-function overwrite of `_tokenOwner` via `listToken`.
- **LLM-guided taint (ACTaint [22]).** ACTaint's Contract Variable Dependency Graph (CVDG) tracks dependencies at the variable level and records that both functions access `_tokenOwner`. The CVDG does not resolve mapping keys. It therefore cannot distinguish `_tokenOwner[base.token]` in `listToken` from `_tokenOwner[token]` in `withdrawTokens`. Its taint analysis then classifies the `require` guard as valid protection and misses the ownership-hijacking vector.
- **Standalone LLM (GPT-4o).** Given all 1,600+ lines, GPT-4o's attention dilutes across dozens of irrelevant functions. In our runs it either hallucinated a non-existent guard on `listToken` or deemed public registration "intentional."

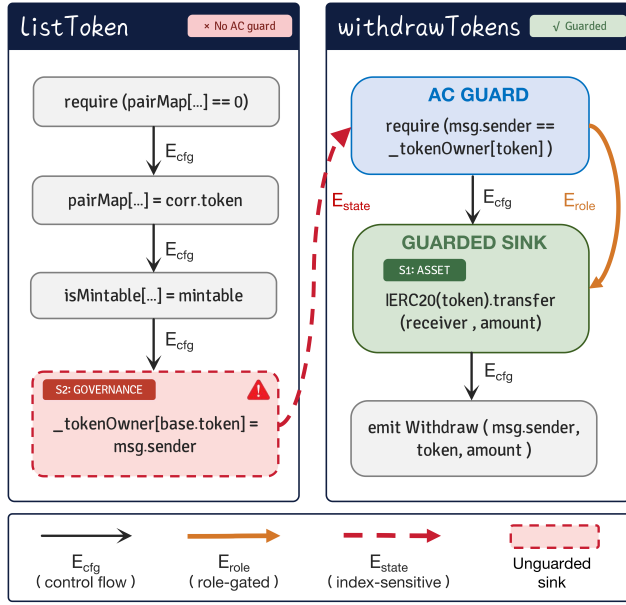


Figure 2: ACPG fragment for the XBridge vulnerability.

Detecting this vulnerability demands cross-function state tracking at the mapping-key level, since variable-level dependency alone cannot distinguish the two access patterns. The 1,600 lines of surrounding code must then be distilled to the small subset of statements that carry authorization semantics. The resulting policy judgment has no predefined template to match against. Section 3 describes how ACLens addresses these requirements.

3 ACLens

3.1 Overview

Detecting AC vulnerabilities requires first locating the operations that carry privileged effects and delimiting the security-relevant context around them. It further requires determining whether any feasible execution reaches those operations in violation of the contract’s implicit authorization policy. ACLens delegates these two tasks to structural analysis guided by the program graph and multi-agent security reasoning, respectively. By design, the first phase determines what each agent in the second phase is permitted to see, ensuring that semantic judgment is always grounded in structurally scoped evidence. Figure 3 presents the overall workflow.

Graph-Guided Structural Analysis (§3.2) builds an Access Control Property Graph (ACPG) that captures caller-dependent guard semantics and cross-function state dependencies, and uses them to identify authorization-relevant sinks. Around each sink, relevance-guided slicing then extracts a Sink-Conditioned Execution Environment (SCEE) based on the sink set and graph topology.

Multi-Agent Security Reasoning (§3.3) consists of trace reconstruction, policy inference, and compliance verification. The Trace agent reconstructs the sink-reaching execution trace for each sink. The Auditor infers the intended policy from code structure and graph annotations. The Verifier then aligns these two outputs to

judge whether the reconstructed trace violates the inferred policy. The evaluation in §4 quantifies the benefit of this separation.

3.2 Graph-Guided Structural Analysis

Passing the full contract to phase two would obscure authorization logic among irrelevant code, while naive slicing on a standard dependency graph would discard the cross-function state flows that AC judgment depends on. Graph-guided structural analysis addresses both requirements through three steps: ACPG construction, critical sink identification, and relevance-guided context slicing.

3.2.1 ACPG Construction. We first construct a Code Property Graph (CPG) [46] from Slither’s [12] parsing results. The CPG jointly encodes control flow, data dependence, and control dependence over program statements, allowing downstream analysis to simultaneously trace execution paths, data flows, and branching conditions within one structure.

For AC analysis, two aspects of a standard CPG remain implicit. First, the authorization semantics is implicit. For example, predicates that enforce authorization, such as the one in `require(msg.sender == owner)`, are represented in the same way as ordinary predicates like `amount > 0`. Second, a standard CPG treats all accesses to the same mapping variable as equivalent, regardless of which key is used. It cannot distinguish whether two functions reading and writing balances operate on the same entry or on entirely different ones. This prevents the analysis from tracking how a state change in one function affects the data that another function reads or guards, which is essential for detecting cross-function AC vulnerabilities. These two gaps motivate the ACPG’s extensions.

The first extension encodes guard semantics. A conditional check qualifies as an *authorization guard* for a downstream operation if its predicate depends on the caller’s identity, whether directly or through transitive data flow, and if it dominates the operation in the control-flow graph, i.e., every path from the function entry to that operation passes through the check.

In Solidity, the primary on-chain sources of caller identity are `msg.sender` and `tx.origin`. Our implementation tracks transitive dependencies from these two primitives via Slither’s data-flow analysis. Authorization guards take the form of inline `require` statements, `if` branches, or modifier bodies that encapsulate such checks. When both criteria are met, the ACPG records an E_{role} edge from the guard to the protected operation, allowing later stages to directly query whether a given operation is protected by an authorization guard.

The second extension resolves cross-function state connections at the mapping-key level. Mapping variables in DeFi contracts serve as shared accounting structures across multiple principals, yet a standard CPG treats every access to the same mapping identically regardless of the index key used. AC analysis needs only to determine whether each access targets the caller’s own entry or a different principal’s. The ACPG answers this through a *symbolic key* attached to each mapping access, a tuple recording the provenance of each index expression. For instance, `balances[msg.sender]` carries the key $\langle sender \rangle$, while `allowances[msg.sender][spender]` with parameter `spender` carries $\langle sender, param:spender \rangle$.

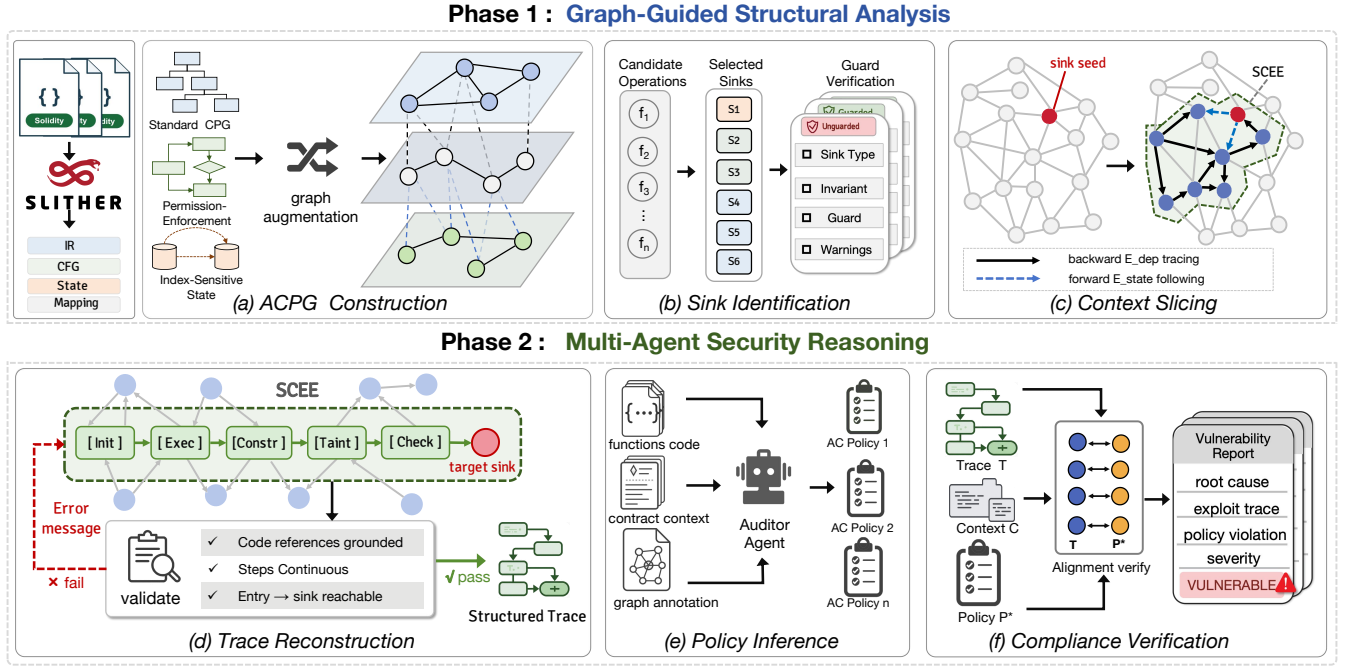


Figure 3: Overview of the ACLens framework. Phase 1 performs structural analysis guided by the program graph to construct the ACPG, identify critical sinks, and extract Sink-Conditioned Execution Environments (SCEEs). Phase 2 performs multi-agent security reasoning, where dedicated agents reconstruct sink-reaching traces, infer intended policies, and verify their alignment.

When a symbolic key contains parameter references, the analysis resolves each by following interprocedural call edges (E_{call}) until a concrete origin (e.g., `msg.sender`) or a public entry point is reached. The analysis then aligns write and read keys for the same variable and compares their origins at each index level. Matching origins yield high confidence, distinct parameter sources yield medium, and unresolved locals yield low; incompatible origins (e.g., `sender` vs. a constant) produce no edge. The minimum confidence across positions scales the E_{state} edge weight as $w = 0.9 \times c$ ($c \in \{1.0, 0.67, 0.33\}$), so `balances[msg.sender]` in one function connects at weight 0.9 to the same entry elsewhere while unrelated accesses remain disconnected. Figure 2 illustrates these connections on XBridge (§2).

The resulting ACPG encodes the structural evidence that subsequent analysis builds on. Sink identification (§3.2.2) queries these edges to locate control variables and determine whether each sink is guarded, while context slicing (§3.2.3) uses the edge weights to extract code regions that preserve the security-relevant context for downstream reasoning.

3.2.2 Critical Sink Identification. Given the ACPG, the next step is to determine *which* operations in a contract require authorization. We call an operation a *critical sink* if an unauthorized execution would violate at least one contract-level security invariant. A security invariant here refers to a property the contract should maintain throughout normal operation, whose violation leads to irreversible security consequences.

Definition 1 (Critical Sink). Given an ACPG G_{AC} , an operation node $s \in V$ is a critical sink if there exists a security invariant $I \in \{\text{GOVERNANCE}, \text{ASSET}, \text{AUTHORIZATION}\}$ such that an unprivileged caller performing s would violate I :

$$S_{crit} = \{s \in V \mid \exists I. \text{effect}(s, c_{\perp}) \models \neg I\} \quad (1)$$

where $c_{\perp}$ models a caller that holds no privileged role in the contract, and $\text{effect}(s, c_{\perp})$ denotes the post-state that results from executing s under caller $c_{\perp}$, assuming s is reached regardless of any guards on the enclosing path. This identifies operations whose uncontrolled execution would be harmful; whether the guards currently in place enforce an adequate policy is assessed separately during policy inference (§3.3).

Analyzing documented DeFi incidents [18, 47], we classify the damage from uncontrolled execution into three security invariants. GOVERNANCE covers operations that alter the contract’s own access policy. ASSET covers external calls and value transfers that cause direct financial loss. AUTHORIZATION covers writes to shared state affecting other users’ funds or permissions, pervasive in DeFi’s mapping-based accounting but largely unaddressed by existing tools [12, 16, 22, 25]. We instantiate these invariants into six sink categories based on the Solidity operations that can violate them (Table 1).

S1, S3, S4, and S5 correspond to operations recognized in prior AC analysis [12, 16, 22]. S2 and S6 are enabled by the ACPG extensions from §3.2.1. For S2, guard edges (E_{role}) provide a structural alternative to heuristic name matching [22, 25]. A state variable

Table 1: Critical sink taxonomy.

Invariant	Sink	Detection criterion
GOVERNANCE	S2. Policy-var. mutation	Write to variable read by a caller-identity guard
	S3. Destruction	selfdestruct instruction
	S5. Open initializer	Init entry without a caller-identity guard
ASSET	S1. External interaction	External call or value transfer
AUTH.	S6. Cross-user mutation	Mapping write with resolved key $\neq$ msg.sender
(inherited)	S4. Transitive closure	Reachable from S1–S3 or S6 via E_{call}

read at the source of a guard edge is governance-relevant, so writes to it are classified as S2 sinks. For S6, key-resolved state edges (E_{state}) distinguish whether a mapping write targets the caller's own entry or another user's, capturing cross-user mutations that standard representations lack the precision to detect [47].

Before enumeration, we exclude entry points whose access is fixed by the execution model or limited to caller-local effects, such as constructors, fallbacks, and standard inherited token wrappers. After enumeration, we query the ACPG to determine whether a guard dominates each sink, provisionally marking it as *unguarded*, *guarded*, or *excluded*. Whether existing guards enforce the intended policy is assessed in §3.3.

3.2.3 Relevance-Guided Context Slicing. Classical program slicing [14] on a standard CPG does not distinguish authorization guards from ordinary predicates, nor does it track state flows at the mapping key level. Slices derived from such a graph may therefore omit the cross-function guard conditions and index-sensitive state connections that AC judgment requires. Because the ACPG already encodes these relationships as typed, weighted edges (§3.2.1), we define a relevance-guided slicing procedure over this structure.

For each function f , let $S_f \subseteq S_{crit}$ denote the critical sinks within f identified in §3.2.2. We extract a *Sink-Conditioned Execution Environment* (SCEE) around each sink by propagating relevance over the dependency edge set $E_{dep} = \{e \in E \mid w(e) > 0\}$. This set retains all ACPG edges that carry dependency semantics, excluding structural edges with zero weight (control-flow and post-dominator).

Edge weights reflect how directly each edge type encodes authorization semantics. Guard and modifier edges carry the highest weight ($w=1.0$) as they represent explicit permission checks. State edges rank second, scaled by the key alignment confidence from §3.2.1. Other dependency edges carry lower weights proportional to their indirect contribution. We formulate the slicing as a maximum product path problem on a priority queue. Each sink starts with relevance 1.0, and relevance decays multiplicatively along edges. The optimal relevance of a node v satisfies

$$rel(v) = \max\left(\max_{(v,u) \in E_{dep}} [rel(u) \cdot \hat{w}(v,u) \cdot \alpha], \max_{(u,v) \in E_{state}} [rel(u) \cdot w(u,v) \cdot \alpha]\right) \quad (2)$$

with base case $rel(s) = 1$ for all $s \in S_f$. Here $\alpha = 0.85$ is the per-hop decay factor, and $\hat{w}(v,u) = \max_{e \in par(v,u)} w(e)$ selects the highest weight among parallel edges connecting v and u in the multigraph. The first term propagates relevance backward from sinks along dependency edges, collecting predecessor nodes that supply AC context. The second term extends propagation forward along state edges, because whether a state write constitutes a

Algorithm 1 Relevance-Guided Context Slicing

Input: ACPG $G_{AC}=(V,E)$, sinks S_f of function f , decay α , threshold τ

Output: sink-conditioned execution environment $SCEE_f$

// $par(v,u)$: parallel edges between v and u in the multi-graph

```

1:  $E_{dep} \leftarrow \{e \in E \mid w(e) > 0\}$  // dependency edges only
2:  $rel[v] \leftarrow 0$  for all  $v \in V$ 
3:  $H \leftarrow$  empty priority queue;  $\mathcal{R} \leftarrow \emptyset$ 
4: for each sink  $s \in S_f$  do
5:    $rel[s] \leftarrow 1.0$ ; push  $(1.0, s)$  into  $H$ 
6: while  $H \neq \emptyset$  do
7:    $(r_u, u) \leftarrow \text{EXTRACTMAX}(H)$ 
8:   if  $r_u < rel[u]$  then
9:     continue // superseded entry
10:   $\mathcal{R} \leftarrow \mathcal{R} \cup \{u\}$ 
11:  for each  $(v, u) \in E_{dep}$  do // backward: predecessors
12:     $r_v \leftarrow r_u \cdot \max_{e \in par(v,u)} w(e) \cdot \alpha$ 
13:    if  $r_v \geq \tau$  and  $r_v > rel[v]$  then
14:       $rel[v] \leftarrow r_v$ ; push  $(r_v, v)$  into  $H$ 
15:  for each  $(u, v) \in E_{state}$  do // forward: state readers
16:     $r_v \leftarrow r_u \cdot w(u, v) \cdot \alpha$ 
17:    if  $r_v \geq \tau$  and  $r_v > rel[v]$  then
18:       $rel[v] \leftarrow r_v$ ; push  $(r_v, v)$  into  $H$ 
19: return BUILDSCCE( $\mathcal{R}$ )

```

vulnerability depends in part on how downstream code reads or guards that variable. Nodes whose relevance falls below a threshold $\tau = 0.05$ are pruned; the resulting SCEE comprises all surviving nodes. Algorithm 1 gives the complete procedure.

The algorithm follows Dijkstra-style relaxation on a max-product semiring, computing optimal relevance in $O((|V|+|E|) \log |V|)$ time. With $\alpha=0.85$ and $\tau=0.05$, a path of weight-1.0 edges (guard, modifier, or role edges) retains relevance above τ for up to 18 hops ($0.85^{18} \approx 0.054$), while a path of call edges (weight 0.5) drops below τ at hop 4 ($0.425^4 \approx 0.033$). The weight assignment biases the SCEE toward nodes connected to the sink through edges that encode permission semantics, while nodes reachable only via low-weight indirect paths are excluded.

Running example. On XBridge (Figure 2), ACPG construction links the `_tokenOwner` write in `listToken` to the downstream read in `withdrawTokens`. Sink identification marks this write as S2 (GOVERNANCE) and the transfer in `withdrawTokens` as S1 (ASSET). Guard verification classifies `withdrawTokens` as GUARDED and `listToken` as UNGUARDED. Starting from these sinks, relevance-guided slicing retains the full state chain from the `_tokenOwner` write to its guard read, while auxiliary operations with no dependency path to either sink fall below τ and are excluded.

3.3 Multi-Agent Security Reasoning

Once phase one fixes the evidence boundary, the analysis must determine whether each critical operation is adequately protected under an authorization policy that the contract never explicitly states. Phase two assigns this judgment to three agents with separated responsibilities. The Trace Reconstructor (A_{trace}) reconstructs

Prompt for Trace Reconstructor	
[Input]	SCEE source {scee}, target sinks {sinks}
[Task]	For each sink in {sinks}, reconstruct a structured execution trace from the externally reachable entry point to the sink within the evidence boundary {scee}.
[Methodology]	For each sink, perform five steps: 1. <i>State Init</i> — The caller is unconstrained; state variables hold defaults. 2. <i>Forward Exec</i> — Traverse entry $\rightarrow$ sink, inlining modifiers and internal calls. 3. <i>Constraint Accum</i> — Record every require/if/assert as path condition π . 4. <i>Identity Propagation</i> — Track msg.sender flow into π or sink operands. 5. <i>Feasibility</i> — Verify π is satisfiable under σ_0 .
[Output]	Each step: {position, type $\in$ {MODIFIER, CONSTRAINT, STATEWRITE, EXT CALL}, code_ref, formula}

Figure 4: The prompt for the Trace Reconstructor agent.

the execution trace reaching each sink within the SCEE. The Auditor (A_{audit}) infers the intended authorization policy for the target function. The Verifier (A_{verify}) judges whether the reconstructed trace violates the inferred policy and whether its effect extends beyond the caller's own state. This separation prevents a single model from anchoring on its initial interpretation and propagating bias into downstream judgments. Section 4 quantifies the effect.

3.3.1 Trace Reconstruction. In Solidity, authorization is enforced primarily through modifiers attached to the function signature and through `require` statements placed before the function body's first branch [11]. Prior AC detectors also target these two mechanisms [16, 25]. Both mechanisms execute at function entry and therefore dominate every subsequent node in the control-flow graph. If no guard exists at function entry, every path from entry to the sink is equally unprotected. This structural property distinguishes AC vulnerabilities from reentrancy [3] or transaction ordering dependence [47], where exploitable behavior emerges only under specific execution interleavings. Because the absence of an entry-level guard is path-independent, a single verified trace that reaches the sink without encountering an adequate guard constitutes a sufficient vulnerability witness. A_{trace} therefore reconstructs, for each critical sink identified in §3.2.2, exactly one execution trace from the function's externally reachable entry point to the sink within the SCEE (§3.3.3 formalizes the sufficiency condition in eq. (3)).

The reconstruction follows a five-step protocol (Figure 4) that walks forward from function entry to the target sink, accumulating path conditions and tracking how the caller's identity propagates into guards and sink operands. The protocol concludes with a feasibility check confirming that the accumulated path condition is satisfiable. Each step in the output trace is anchored to a specific code fragment in the SCEE. A deterministic validator then confirms that each referenced fragment exists in the SCEE, that consecutive steps are connected in the control-flow graph, and that the overall path is reachable from the entry point. Traces that fail any check are returned to A_{trace} for reconstruction, with up to two retries. Because the SCEE has already narrowed the reasoning scope, 89.1% of sinks pass validation on the first attempt.

Prompt for Auditor	
[Input]	Target function {code}, contract context {context}, peer functions {peers}, graph annotations {annotations}
[Task]	Infer the intended access control policy $\mathcal{P}_f^* = (\mathcal{A}_f, \Phi_f)$ for {code}: (1) required caller class (<i>Public</i> , <i>Owner</i> , <i>Role</i> , <i>DAO</i>); (2) state preconditions that must hold. Use {context} to resolve types and roles referenced in {code}. Use {annotations} as supplementary structural evidence.
[Peer Comparison]	If ≥ 2 comparable peers consistently enforce caller identity guards while the target lacks equivalent protection, this asymmetry is evidence of a missing restriction. Uniformly permissionless peers indicate the target is permissionless by design. Fewer or conflicting peers lower confidence but do not preclude inference; use {annotations} as supplementary evidence.
[Output]	{caller_class, state_preconditions, supporting_peers, protection_pattern, confidence}

Figure 5: The prompt for the Auditor agent.

3.3.2 Policy Inference. The Auditor infers an authorization policy $\mathcal{P}_f^* = (\mathcal{A}_f, \Phi_f)$ for each function f that contains at least one sink identified in §3.2.2, where $\mathcal{A}_f \in \{\text{Public}, \text{Owner}, \text{Role}, \text{DAO}\}$ specifies the required caller class and Φ_f lists the state preconditions that must hold before execution. The granularity is per function rather than per sink, because Solidity guards are enforced at function entry (§3.3.1) and all sinks within the same function therefore share the same authorization boundary. Within a single contract, developers typically protect operations with similar security implications in a similar way. Deviations from such recurring patterns have been shown to be a reliable signal for latent defects in prior work on inconsistency-based bug detection [1, 10], and SPCon [25] confirmed this regularity for access control in smart contracts.

To exploit this regularity, A_{audit} compares the target function against structurally similar *peer functions* from the same contract. It receives four inputs (Figure 5): the target function's source, contract-level context (state variable declarations and modifier definitions), a ranked set of peers, and the graph annotations produced by phase one (per-sink guard status, control-variable alerts, and cross-user write flags from §3.2.2). Peers are selected based on structural overlap that the ACPG makes observable in three forms: (1) shared writes to variables in $\mathcal{V}_{crit}$ (sink operands $\cup$ control variables from §3.2.2), (2) sinks classified under the same security invariant (Table 1), and (3) shared modifiers or guard predicates referencing the same role variable. Candidates with more overlapping signals rank higher. When two or more top-ranked peers enforce caller identity guards while the target lacks equivalent protection, the asymmetry constitutes evidence of a missing restriction rather than a deliberate design choice. Conversely, when all comparable peers are uniformly permissionless or scoped to the caller's own state, the target is presumed open by design. If fewer than two peers are available or their patterns conflict, the Auditor lowers its confidence and relies primarily on graph annotations as supplementary evidence.

3.3.3 Compliance Verification. Given the traces from A_{trace} , the inferred policy from A_{audit} , and the contract context, the Verifier determines their alignment. For a given sink s with locally validated

Prompt for Verifier	
[Input]	Inferred policy {policy}, reconstructed trace {trace}, contract context {context}
[Task]	Given {context}, determine whether {trace} violates {policy} and whether the effect extends beyond the caller's own state.
[Judgment]	Flag a policy violation if {trace} reaches a sensitive operation without satisfying the required caller class or state preconditions. Classify as VULNERABLE only when the violation affects shared or protocol-level state (governance and configuration variables, cross-user mapping entries, external asset transfers). Caller-local operations are SAFE.
[Output]	{status ∈ {VULNERABLE, SAFE, UNKNOWN}, reasoning}

Figure 6: The prompt for the Verifier agent.

trace set $\mathcal{T}_s$ and inferred policy $\mathcal{P}_f^*$, we write $\text{NonLocal}(T)$ for traces whose effects are not confined to caller-local state. The positive judgment is expressed in eq. (3).

$$\text{VULNERABLE}(s) \iff \exists T \in \mathcal{T}_s : T \not\models \mathcal{P}_f^* \wedge \text{NonLocal}(T) \quad (3)$$

where $T \not\models \mathcal{P}_f^*$ means that the trace violates the inferred caller class or state preconditions for f . $\text{NonLocal}(T)$ holds when the trace affects shared or protocol-level state rather than only caller-local entries. This includes writes to governance and configuration variables, to aggregate accounting state, to mapping entries whose effective principal is not bound to `msg.sender` or to a parameter already constrained to equal `msg.sender`, and external asset transfers directed to recipients not bound to the caller. The second conjunct ensures that ACLens does not flag caller-only self-service behavior as a vulnerability. A single verified violating trace suffices for a positive finding; exhausting remaining branches is unnecessary. When neither condition triggers, *Averify* conservatively outputs UNKNOWN. Constraining the Verifier to trace-policy alignment also prevents it from re-inferring the policy or hypothesizing attack scenarios unsupported by its inputs. Figure 6 excerpts the core instructions.

Running example. On XBridge, the Auditor notes that `withdrawTokens` guards writes to `_tokenOwner` with a caller identity check, and infers the same policy for `listToken` ($\mathcal{A}_f = \text{Owner}$). The reconstructed trace reaches the `_tokenOwner` overwrite without any such check. Since `_tokenOwner` also governs fund withdrawal in `withdrawTokens`, the Verifier confirms both conjuncts of eq. (3) and reports VULNERABLE.

4 Evaluation

We evaluate ACLens by answering four research questions.

RQ1: How does ACLens perform in detecting AC vulnerabilities compared to existing approaches?

RQ2: How well does ACLens generalize across different LLM backbones?

RQ3: What is the contribution of each design component to the overall detection result?

RQ4: How much does structural analysis reduce the analysis context, and what cost does the resulting reduction enable?

4.1 Experimental Setup

All LLM agents return JSON-formatted outputs. We set temperature to 0 and fix the random seed to 42, following standard practice in LLM-based vulnerability detection [22]. Each benchmark project is processed end-to-end without manual intervention. Under these settings the pipeline produces identical outputs for identical inputs. All experiments ran on a MacBook Pro with Apple M3 Max.

Metrics. Following ACTaint [22] and AChecker [16], we report TP, FP, FN, Recall R , and F1. We adopt a strict *function-level* evaluation protocol. For function-level evaluation on the DeFi set, a reported function counts as TP only when it independently exposes an exploitable root cause consistent with the incident. Functions that do not meet this criterion count as FP, and unmatched benchmark functions count as FN.

4.2 Benchmarks

Our evaluation uses two complementary benchmarks: **CVE**, the 15-contract CVE dataset widely adopted in prior work [16, 22, 25], and **DeFi**, a benchmark we construct from confirmed on-chain DeFi AC exploits from 2017 to 2024. CVE covers classic single-function patterns on which existing tools already achieve high recall (ACTaint: 93.3%). The DeFi dataset targets production DeFi contracts with cross-function authorization logic, where AC exploits cause the largest share of financial losses [18] yet remain largely undetected. **DeFi.** We screen all incidents in DeFiHackLabs [39] through 2024 and retain those whose root cause is an AC vulnerability and whose source code is verified on-chain. This yields 54 confirmed exploits across six chains, covering 750 contract, library, and interface definitions totaling 85.6 KLoC. We then exclude 8 cases that are not genuine AC flaws, such as Merkle-guarded mints and intentionally permissionless routers. The remaining set contains 46 validated projects.

To establish function-level ground truth, two researchers with over three years of smart contract auditing experience independently reviewed each project. For every case they traced the on-chain exploit transaction, identified the root-cause function(s), and annotated all functions whose unguarded state independently enables the exploit. Disagreements were resolved through joint re-examination of exploit traces and contract state transitions, producing a final set of 97 vulnerable functions across the dataset.

4.3 Baselines

We compare ACLens against six baselines spanning the main technical directions in AC detection. The static tools cover pattern matching, symbolic execution, and bytecode dataflow analysis; the two LLM tools represent the closest prior work in agent-guided AC analysis and a leading general-purpose LLM auditor, respectively. For the main comparison in RQ1, all LLM-based methods use GPT-4o, so performance differences reflect methodology rather than model capability.

Static analysis and symbolic execution. **Slither** [12] is an industry-standard pattern-based analyzer. We count findings from its AC-related detectors. **Mythril** [30] performs symbolic execution on EVM bytecode. **SPCon** [25] mines role-permission relationships from bytecode via frequent-itemset analysis. **AChecker** [16] traces

msg. sender dependencies through bytecode-level data flow with symbolic filtering.

LLM-based detection. ACTaint [22] is a dual-agent system guided by a Critical Variable Dependency Graph (CVDG) for LLM-based taint analysis. GPTLens [20] uses an auditor-critic pair with shared context. We adapt its auditor prompt by replacing the general vulnerability taxonomy with AC-specific categories while preserving the original auditor-critic interaction structure.

ACTaint and GPTLens are reproduced from their published descriptions. We validate our ACTaint reproduction against the originally reported CVE recall and obtain the same result (14/15).

All baselines are evaluated on the DeFi dataset with the same function-level evaluation protocol.

4.4 Results

4.4.1 RQ1: Detection Effectiveness. We first evaluate ACLens on CVE, the 15-contract CVE benchmark widely adopted in prior AC detection work [16, 22, 25]. ACLens detects all 15 cases, followed by ACTaint (14/15), AChecker (12/15), SPCon (9/15), GPTLens (5/15), Mythril (4/15), and Slither (1/15). The case that ACTaint misses involves an external function that directly modifies a critical state variable without any msg. sender dependency in its control flow. ACTaint’s taint agent searches for a propagation path from an untrusted source to the sink and, finding none, classifies the function as safe. ACLens identifies the function as an unguarded sink during phase one and flags it without requiring a taint path.

Table 2 presents the DeFi dataset results. ACLens detects 81 of the 97 vulnerable functions (Table 2), whereas ACTaint, the strongest baseline, detects 36. We inspected the cases on which the two systems disagree. The majority of additional detections by ACLens involve completely unguarded entry points that modify critical state or trigger external calls. Because these functions contain no msg. sender check, ACTaint’s taint agent finds no propagation path to evaluate and does not flag them. ACLens catches them because sink identification in phase one flags unguarded critical operations independently of taint reachability; the XBridge vulnerability (§2) illustrates this pattern at the cross-function level. A smaller group of additional detections involves functions with partial guards that ACTaint considers sufficient but that ACLens’s policy inference judges incomplete based on cross-function state dependencies visible in the ACPG.

GPTLens detects 18 functions but produces 43 false positives. Its auditor receives the full contract source and frequently hallucinates non-existent guards or dismisses missing protections as intentional. The four static analysis tools achieve near-zero recall for distinct reasons. Mythril’s symbolic execution encounters path explosion or analysis timeouts on complex DeFi contracts, and its SWC detectors do not target AC vulnerabilities. Slither’s built-in AC rules target misuse of existing guards (e.g., unprotected selfdestruct) rather than missing guards, capturing only 8 of 97 functions. AChecker’s bytecode-level data-flow analysis encounters frequent timeouts on DeFi contracts with complex control flow and extensive external calls. SPCon infers permission policies by mining on-chain transaction histories [25], yet many vulnerable DeFi functions lack sufficient transaction records for role mining, leaving SPCon unable to derive a policy.

Table 2: Detection performance on the DeFi dataset

Method	TP	FP	FN	P(%)	R(%)	F1(%)
Slither	8	22	89	26.7	8.2	12.6
Mythril	0	0	97	—	0.0	—
SPCon	1	0	96	100.0	1.0	2.0
AChecker	0	0	97	—	0.0	—
GPTLens	18	43	79	29.5	18.6	22.8
ACTaint	36	72	61	33.3	37.1	35.1
ACLens	81	116	16	41.1	83.5	55.1

Table 3: Performance comparison across different LLM backbones

Tool	Model	TP	FP	P(%)	R(%)	ΔP	ΔR
ACLens	GPT-4o	81	116	41.1	83.5		
ACLens	GPT-4o-mini	79	119	39.9	81.4	−1.2	−2.1
ACLens	DeepSeek-R1	80	115	41.0	82.5	−0.1	−1.0
ACTaint	GPT-4o	36	72	33.3	37.1		
ACTaint	GPT-4o-mini	42	427	9.0	43.3	−24.3	+6.2
ACTaint	DeepSeek-R1	39	118	24.8	40.2	−8.5	+3.1

Answer for RQ1: ACLens detects all 15 CVE cases and 81 of 97 DeFi dataset functions, outperforming the strongest baseline by 46.4 recall points and 20.0 F1 points. The additional detections are predominantly unguarded entry points where no taint path exists for prior tools to evaluate.

4.4.2 RQ2: Phase-Two Backbone Sensitivity. To answer RQ2, we examine whether detection performance remains stable when the LLM backbone changes. We keep the pipeline structure and prompts fixed and replace only the backbone, running both ACLens and ACTaint with GPT-4o, GPT-4o-mini, and DeepSeek-R1 [8].

Table 3 shows that ACLens varies little across backbones, with recall staying within a 2.1 pp band and false positives between 115 and 119. ACTaint fluctuates far more. Under GPT-4o-mini it recovers six additional TPs but false positives rise from 72 to 427, dropping precision to 9.0%; DeepSeek-R1 shows the same trend at smaller magnitude (FP = 118, P = 24.8%).

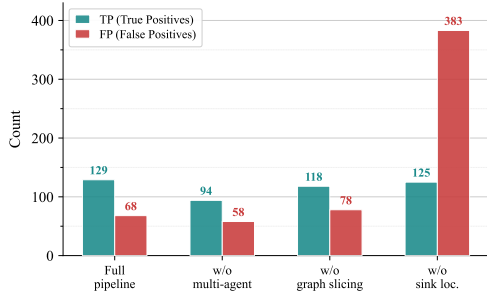
Because phase one of ACLens fixes critical functions and evidence scope before any LLM call, backbone quality affects only the interpretation of a focused context. ACTaint delegates both scoping and judgment to the LLM, compounding errors when the backbone weakens. Practically, ACLens can switch to GPT-4o-mini while losing only 2 TPs.

Answer for RQ2: Swapping the backbone moves ACLens’s recall by at most 2.1 percentage points and its false-positive count by at most 4. ACTaint fluctuates much more, with false positives rising from 72 to 427 under GPT-4o-mini.

4.4.3 RQ3: Phase Contribution. To answer RQ3, we build three ablation variants and evaluate them on the DeFi dataset with GPT-4o. *w/o multi-agent* collapses phase two into a single LLM call that still receives the SCEE and graph annotations from phase

Table 4: Performance comparison in the ablation study

Configuration	TP	FP	FN	P(%)	R(%)	F1(%)
Full two-phase system	81	116	16	41.1	83.5	55.1
w/o multi-agent	65	87	32	42.8	67.0	52.2
w/o graph slicing	77	119	20	39.3	79.4	52.6
w/o sink identification	81	429	16	15.9	83.5	26.7

**Figure 7: TP and FP counts in the ablation study**

one. *w/o graph slicing* retains phase-two reasoning but replaces the scoped SCEE with the full contract source. *w/o sink identification* disables phase one’s sink filter and runs the full system on every public/external function.

Removing multi-agent reasoning causes the largest recall drop. TP decreases from 81 to 65 and recall falls from 83.5% to 67.0%. The 16 newly missed cases concentrate on multi-hop privilege escalation chains. When trace construction and policy judgment share a single prompt, the model tends to rationalize missing guards as intentional design rather than flag them as violations.

Without graph slicing, the LLM receives the full contract source instead of the scoped SCEE. TP drops from 81 to 77 and recall decreases to 79.4%. All four newly missed functions belong to projects exceeding 1,500 lines, where the AC-relevant statements are buried among hundreds of unrelated functions and the LLM fails to locate the missing guard.

Removing sink identification has no effect on recall (TP stays at 81) but inflates false positives from 116 to 429 (Figure 7), cutting F1 from 55.1% to 26.7%. The additional FPs come from functions that contain no security-relevant operations; their lack of a guard is benign by design, and only the sink filter prevents them from entering the analysis pipeline.

In summary, removing any of the three components drops F1 below the full system’s 55.1%, but the failure modes differ. Sink identification controls false positives, graph slicing preserves recall on large contracts, and multi-agent separation preserves recall on multi-hop privilege chains.

Answer for RQ3: Each component addresses a distinct failure mode. Removing multi-agent reasoning drops recall by 16.5 pp; removing graph slicing drops recall by 4.1 pp on large contracts; removing sink identification inflates false positives from 116 to 429. All three variants fall below the full system’s 55.1% F1.

Table 5: Cost profile for the five largest DeFi dataset projects

Project (repr. function)	LoC	Tokens (K)	Time (s)	Cost (€)
approveToken	4,053	109.3	27	2.0
swap	4,008	34.6	23	0.7
transferFrom	3,367	42.4	20	0.8
setToken	3,070	86.7	29	1.9
withdraw	2,488	82.8	19	1.6
All (mean)	1,375	59.0	22	1.2

4.4.4 RQ4: Scoping Efficiency and Cost. To answer RQ4, we measure how graph-guided slicing changes the input that reaches phase two. Across all functions in the DeFi dataset projects, SCEEs average **92 whitespace tokens** per function (roughly 120 LLM subword tokens), versus 6,333 tokens for the full contract source, a 97.9% average reduction. Most of a contract’s code is simply irrelevant to any single AC decision.

Table 5 profiles analysis cost under GPT-4o-mini (\$0.15/1M input, \$0.60/1M output tokens) on the five largest DeFi dataset projects.

Across all projects, the mean cost is 1.2 € per project (max 7.5 €), consuming 59.0K tokens on average with a mean wall-clock time of 21.9 s. Cost tracks the number of critical functions that survive phase one more closely than raw code volume.

Answer for RQ4: Graph-guided slicing reduces the per-function input from 6,333 tokens to 92 tokens on average (97.9%). Under GPT-4o-mini, the mean analysis cost is 1.2 €/project, and that cost tracks the number of surviving critical functions rather than raw code volume.

4.5 Error Analysis

We manually reviewed all false negatives and false positives on the DeFi dataset to identify the root causes of remaining detection gaps.

False negatives. We identified three categories among the 16 missed functions.

Six encode authorization semantics within business logic rather than in an explicit guard. For example, a DEX swap function may rely on slippage bounds and price oracle checks as its only protection. Because the authorization constraints appear as branch-level business conditions rather than entry-level caller checks, the Verifier cannot construct sufficient evidence to confirm a violation and returns UNKNOWN (§3.3.3).

Another five functions have canonical ERC-20 names (burn, transfer, transferFrom) but implement non-standard logic such as tax mechanisms or rebasing [44]. In the DeFi dataset, standard-name functions with canonical semantics outnumber such variants 12 : 1, so the system’s prior strongly favors classifying them as benign.

The remaining five are engineering gaps: three attribution mismatches that become TPs under contract-level evaluation, and two Slither compilation failures.

False positives. We categorized the 116 false positives into three groups.

The largest group (55 cases, 47%) involves intentionally permissionless operations such as deposit, withdraw, and liquidate-Borrow, which are open by design in DeFi lending protocols. This reflects insufficient domain priors rather than a structural scoping error.

The second group (40 cases, 34%) consists of locally coherent but globally infeasible traces. The reconstructed trace satisfies all branch conditions within the analyzed scope but violates constraints visible only at the whole-contract level, such as multi-day governance timelocks or mutually exclusive preconditions.

The remaining 21 cases (18%) are hallucinated dependencies where the LLM fabricates state connections absent from the contract [37]. The multi-agent design reduces but does not fully eliminate this failure mode (Table 4).

5 Discussion

5.1 Threats to Validity

External validity. The DeFi dataset covers 46 validated projects across six chains and multiple protocol types (DEXes, lending, yield aggregators, token contracts) spanning 2017–2024, and 100% recall on the CVE dataset confirms no regression on simpler patterns. The benchmark remains dominated by missing-modifier flaws in DeFi protocols, however, and generalization to DAO governance and cross-chain bridge contracts remains to be validated.

Construct validity. The evaluation counts true positives at function level, but real exploits operate at transaction level. A single exploit may invoke multiple vulnerable functions, and conversely a single function may participate in several independent attacks. Function-level counting can therefore over- or under-represent the practical security impact of a detection. We mitigate this by requiring each ground-truth function to independently expose an exploitable root cause consistent with the confirmed incident (Section 4), so a function enters the benchmark only when its ungarded state alone suffices to enable the attack.

Data leakage. Some contracts may appear in model pretraining corpora, but the two-phase design exposes only scoped fragments from deterministic analysis rather than full sources, limiting how much memorization can help.

5.2 Future Work

Domain-aware policy inference. Over half the false positives arise from intentionally permissionless DeFi primitives (self-service deposits, standard token operations, Compound-style lending). A retrieval-augmented knowledge base of known permissionless idioms, or a classifier trained on curated DeFi function signatures, could sharpen the boundary between deliberate openness and a genuinely missing guard.

Symbolic path feasibility. Attack paths with globally unsatisfiable constraints, such as multi-day timelocks or mutually exclusive preconditions, form the second major source of false positives. A symbolic back-end could help here, but the main challenge is not only solving constraints; trace steps, guard conditions, and state interactions must first be translated into sound SMT formulas. SMT-based feasibility checking therefore remains future work.

6 Related Work

Static and AC-specialized analysis. Automated analysis of smart contracts has been studied through symbolic execution [13, 27, 29, 30], pattern matching [12, 40], Datalog reasoning [4, 17, 43], fuzzing [31, 42], and formal verification [33, 36]. Large-scale evaluations on tens of thousands of contracts show that these tools are effective at detecting arithmetic and reentrancy vulnerabilities but less accurate on access control, denial of service, and front-running [2, 6, 9, 15, 41]. Even under dedicated AC evaluation, detection remains challenging [23]. Several tools have been developed specifically for this problem. SPCon [25] mines role-permission patterns from on-chain transaction histories. AChecker [16] traces msg.sender dependencies through intraprocedural data flow on bytecode. Ethainter [4] uses Datalog-based taint analysis to track information flow from callers to sensitive operations. SoMo [11] matches modifier structures at the AST level. These tools have advanced AC detection from different angles, each targeting a specific class of authorization patterns.

LLM-based smart contract analysis. Recently, several studies have explored using LLMs for smart contract vulnerability detection. GPTScan [38] uses GPT to match functions against predefined vulnerability scenario descriptions and validates candidates through static confirmation. GPTLens [20] employs an auditor-critic dialogue where both agents share the full contract as context. ACTaint [22] combines a variable-level dependency graph (CVDG) with dual LLM agents, where a sink agent identifies critical variable modifications and a taint agent traces data flow from untrusted sources to sinks. The CVDG tracks dependencies at the variable level, without distinguishing accesses to different entries of the same mapping. Broader evaluations have found that cross-function reasoning remains a persistent bottleneck for LLM-based contract analysis [7, 37], and that ChatGPT-style auditing still exhibits unstable precision on real-world contracts [5]. iAudit [28], PropertyGPT [26], and SmartInv [45] target per-function auditing or property generation rather than AC detection. In the broader software engineering domain, agent role separation has been shown to reduce hallucination in collaborative code reasoning [19, 34].

7 Conclusion

In this paper, we proposed ACLens, a multi-agent framework guided by program graphs for AC vulnerability detection. The first phase scopes the code that carries authorization semantics, while the second phase infers the intended policy and checks whether feasible traces violate it. Our evaluation on two benchmarks shows that this decomposition improves detection effectiveness on real DeFi access control cases across multiple LLM backbones and ablation settings. The main remaining difficulty lies in domain-specific policy understanding rather than structural evidence recovery. These results suggest that reliable AC detection hinges not on showing the model more code, but on first delimiting the evidence that actually carries authorization semantics.

Data Availability

The anonymous replication package, including the analysis framework, curated datasets, and experiment outputs, is publicly available at <https://doi.org/10.5281/zenodo.19220416>.

References

- [1] Mansour Ahmadi, Reza Mirzazade Farkhani, Ryan Williams, and Long Lu. 2021. Finding Bugs Using Your Own Code: Detecting Functionally-similar yet Inconsistent Code. In *30th USENIX Security Symposium (USENIX Security 21)*. USENIX Association, 2025–2040. <https://www.usenix.org/conference/usenixsecurity21/presentation/ahmadi>
- [2] Nicola Atzei, Massimo Bartoletti, and Tiziana Cimoli. 2017. A Survey of Attacks on Ethereum Smart Contracts (SoK). In *Proceedings of the 6th International Conference on Principles of Security and Trust (POST)*. Springer, Cham, 164–186.
- [3] Priyanka Bose, Dipanjan Das, Yanju Chen, Yu Feng, Christopher Kruegel, and Giovanni Vigna. 2022. SAILFISH: Vetting Smart Contract State-Inconsistency Bugs in Seconds. In *Proceedings of the IEEE Symposium on Security and Privacy (S&P)*. IEEE, Piscataway, NJ, USA, 161–178.
- [4] Lexi Brent, Neville Grech, Sifis Lagouvardos, Bernhard Scholz, and Yannis Smaragdakis. 2020. Ethainter: A Smart Contract Security Analyzer for Composite Vulnerabilities. In *Proceedings of the 41st ACM SIGPLAN Conference on Programming Language Design and Implementation (PLDI)*. ACM, New York, NY, USA, 454–469.
- [5] Chong Chen, Jianzhong Su, Jiachi Chen, Yanlin Wang, Tingting Bi, Jianxing Yu, Yanli Wang, Xingwei Lin, Ting Chen, and Zibin Zheng. 2025. When ChatGPT Meets Smart Contract Vulnerability Detection: How Far Are We? *ACM Transactions on Software Engineering and Methodology* 34, 4, Article 100 (2025), 30 pages. doi:10.1145/3702973
- [6] Huashan Chen, Marcus Pendleton, Laurent Njilla, and Shouhuai Xu. 2020. A Survey on Ethereum Systems Security: Vulnerabilities, Attacks, and Defenses. *Comput. Surveys* 53, 3 (2020), 1–43.
- [7] Isaac David, Liyi Zhou, Kaihua Qin, Dawn Song, Lorenzo Cavallaro, and Arthur Gervais. 2023. Do You Still Need a Manual Smart Contract Audit? *arXiv preprint arXiv:2306.12338* (2023).
- [8] DeepSeek-AI. 2025. DeepSeek-R1: Incentivizing Reasoning Capability in LLMs via Reinforcement Learning. *Nature* 645 (2025), 633–638. doi:10.1038/s41586-025-09422-z
- [9] Thomas Durieux, João F. Ferreira, Rui Abreu, and Pedro Cruz. 2020. Empirical Review of Automated Analysis Tools on 47,587 Ethereum Smart Contracts. In *Proceedings of the IEEE/ACM 42nd International Conference on Software Engineering (ICSE)*. ACM, New York, NY, USA, 530–541.
- [10] Dawson Engler, David Yu Chen, Seth Hallem, Andy Chou, and Benjamin Chelf. 2001. Bugs as Deviant Behavior: A General Approach to Inferring Errors in Systems Code. In *Proceedings of the 18th ACM Symposium on Operating Systems Principles (SOSP)*. ACM, 57–72.
- [11] Yuzhou Fang, Daoyuan Wu, Xiao Yi, Shuai Wang, Yufan Chen, Mengjie Chen, Yang Liu, and Lingxiao Jiang. 2023. Beyond “Protected” and “Private”: An Empirical Security Analysis of Custom Function Modifiers in Smart Contracts. In *Proceedings of the 32nd ACM SIGSOFT International Symposium on Software Testing and Analysis (ISSTA)*. ACM, New York, NY, USA, 1157–1168.
- [12] Josselin Feist, Gustavo Grieco, and Alex Groce. 2019. Slither: A Static Analysis Framework for Smart Contracts. In *Proceedings of the 2nd International Workshop on Emerging Trends in Software Engineering for Blockchain (WETSEB)*. IEEE, Piscataway, NJ, USA, 8–15.
- [13] Joel Frank, Cornelius Aschermann, and Thorsten Holz. 2020. ETHBMC: A Bounded Model Checker for Smart Contracts. In *29th USENIX Security Symposium (USENIX Security)*. USENIX Association, Berkeley, CA, USA, 2757–2774.
- [14] Keith B. Gallagher and Suzanne J. Kozaitis. 2025. Program Slicing: A Brief Retrospective. *IEEE Transactions on Software Engineering* 51, 3 (2025), 720–724. doi:10.1109/TSE.2025.3538279
- [15] Asem Ghaleb and Karthik Pattabiraman. 2020. How Effective Are Smart Contract Analysis Tools? Evaluating Smart Contract Static Analysis Tools Using Bug Injection. In *Proceedings of the 29th ACM SIGSOFT International Symposium on Software Testing and Analysis (ISSTA)*. ACM, New York, NY, USA, 415–427.
- [16] Asem Ghaleb, Julia Rubin, and Karthik Pattabiraman. 2023. AChecker: Statically Detecting Smart Contract Access Control Vulnerabilities. In *Proceedings of the IEEE/ACM 45th International Conference on Software Engineering (ICSE)*. IEEE, Piscataway, NJ, USA, 945–956.
- [17] Neville Grech, Michael Kong, Anton Jurisevic, Lexi Brent, Bernhard Scholz, and Yannis Smaragdakis. 2018. MadMax: Surviving Out-of-Gas Conditions in Ethereum Smart Contracts. *Proceedings of the ACM on Programming Languages* 2, OOPSLA (2018), 1–27.
- [18] Hacken. 2024. Web3 Security Report 2024. <https://hacken.io/insights/2024-security-report/>.
- [19] Sirui Hong, Mingchen Zhuge, Jonathan Chen, Xiaowu Zheng, Yuheng Cheng, Ceyao Zhang, Jinlin Wang, Zili Wang, Steven Ka Shing Yau, Zijuan Lin, Liyang Zhou, Chenyu Ran, Lingfeng Xiao, Chenglin Wu, and Jürgen Schmidhuber. 2024. MetaGPT: Meta Programming for a Multi-Agent Collaborative Framework. In *Proceedings of the 12th International Conference on Learning Representations (ICLR)*. OpenReview.net, Vienna, Austria, 1–30.
- [20] Sihao Hu, Tiansheng Huang, Fatih İlhan, Selim Furkan Tekin, and Ling Liu. 2023. Large Language Model-Powered Smart Contract Vulnerability Detection: New Perspectives. *arXiv preprint arXiv:2310.01152* (2023).
- [21] Johannes Krupp and Christian Rossow. 2018. teEther: Gnawing at Ethereum to Automatically Exploit Smart Contracts. In *27th USENIX Security Symposium (USENIX Security 18)*. USENIX Association, 1317–1333.
- [22] Huarui Lin, Zhipeng Gao, Jiachi Chen, Xiang Chen, Xiaohu Yang, and Lingfeng Bao. 2025. ACTaint: Agent-Based Taint Analysis for Access Control Vulnerabilities in Smart Contracts. In *Proceedings of the 40th IEEE/ACM International Conference on Automated Software Engineering (ASE)*. ACM, New York, NY, USA.
- [23] Han Liu, Daoyuan Wu, Yuqiang Sun, Shuai Wang, and Yang Liu. 2025. Have We Solved Access Control Vulnerability Detection in Smart Contracts? A Benchmark Study. In *Proceedings of the 40th IEEE/ACM International Conference on Automated Software Engineering (ASE)*. ACM, New York, NY, USA.
- [24] Nelson F. Liu, Kevin Lin, John Hewitt, Ashwin Paranjape, Michele Bevilacqua, Fabio Petroni, and Percy Liang. 2024. Lost in the Middle: How Language Models Use Long Contexts. *Transactions of the Association for Computational Linguistics* 12 (2024), 157–173.
- [25] Ye Liu, Yi Li, Shang-Wei Lin, and Cyrille Artho. 2022. SPCon: Finding Smart Contract Permission Bugs with Role Mining. In *Proceedings of the 31st ACM SIGSOFT International Symposium on Software Testing and Analysis (ISSTA)*. ACM, New York, NY, USA, 716–727.
- [26] Ye Liu, Yue Xue, Daoyuan Wu, Yuqiang Sun, Yi Li, Miaolei Shi, and Yang Liu. 2025. PropertyGPT: LLM-Driven Formal Verification of Smart Contracts through Retrieval-Augmented Property Generation. In *Proceedings of the Network and Distributed System Security Symposium (NDSS)*. Internet Society, Reston, VA, USA.
- [27] Loi Luu, Duc-Hiep Chu, Hrishi Olickel, Prateek Saxena, and Aquinas Hobor. 2016. Making Smart Contracts Smarter. In *Proceedings of the ACM SIGSAC Conference on Computer and Communications Security (CCS)*. ACM, New York, NY, USA, 254–269.
- [28] Wei Ma, Daoyuan Wu, Yuqiang Sun, Tianwen Wang, Shangqing Liu, Jian Zhang, Yue Xue, and Yang Liu. 2025. Combining Fine-Tuning and LLM-based Agents for Intuitive Smart Contract Auditing with Justifications. In *Proceedings of the IEEE/ACM 47th International Conference on Software Engineering (ICSE)*. ACM, New York, NY, USA, 1742–1754.
- [29] Mark Mossberg, Felipe Manzano, Eric Hennenfent, Alex Groce, Gustavo Grieco, Josselin Feist, Trent Brunson, and Artem Dinaburg. 2019. Manticore: A User-Friendly Symbolic Execution Framework for Binaries and Smart Contracts. In *Proceedings of the 34th IEEE/ACM International Conference on Automated Software Engineering (ASE)*. IEEE, Piscataway, NJ, USA, 1186–1189.
- [30] Bernhard Mueller. 2018. Smashing Ethereum Smart Contracts for Fun and Actual Profit. In *9th Annual HITB Security Conference*. Hack in the Box, Amsterdam, The Netherlands.
- [31] Tai D. Nguyen, Long H. Pham, Jun Sun, Yun Lin, and Quang Minh Tran. 2020. sFuzz: An Efficient Adaptive Fuzzer for Solidity Smart Contracts. In *Proceedings of the IEEE/ACM 42nd International Conference on Software Engineering (ICSE)*. ACM, New York, NY, USA, 778–788.
- [32] OWASP. 2026. Smart Contract Top 10 – 2026. <https://scs.owasp.org/sctop10/>.
- [33] Anton Permenev, Dimitar Dimitrov, Petar Tsankov, Dana Drachler-Cohen, and Martin Vechev. 2020. VerX: Safety Verification of Smart Contracts. In *Proceedings of the IEEE Symposium on Security and Privacy (S&P)*. IEEE, Piscataway, NJ, USA, 1661–1677.
- [34] Chen Qian, Wei Liu, Hongzhang Liu, Nuo Chen, Yufan Dang, Jiahao Li, Cheng Yang, Weize Chen, Yusheng Su, Xin Cong, Juyuan Xu, Dahai Li, Zhiyuan Liu, and Maosong Sun. 2024. ChatDev: Communicative Agents for Software Development. In *Proceedings of the 62nd Annual Meeting of the Association for Computational Linguistics (ACL)*. ACL, Stroudsburg, PA, USA, 15174–15186.
- [35] Kaihua Qin, Liyi Zhou, Benjamin Livshits, and Arthur Gervais. 2021. Attacking the DeFi Ecosystem with Flash Loans for Fun and Profit. In *Proceedings of the 25th International Conference on Financial Cryptography and Data Security (FC)*. Springer, Cham, 3–32.
- [36] Sunbeom So, Myungcho Lee, Jisu Park, Heejo Lee, and Hakjoo Oh. 2020. VERIS-MART: A Highly Precise Safety Verifier for Ethereum Smart Contracts. In *Proceedings of the IEEE Symposium on Security and Privacy (S&P)*. IEEE, Piscataway, NJ, USA, 1678–1694.
- [37] Yuqiang Sun, Daoyuan Wu, Yue Xue, Han Liu, Wei Ma, Lyuye Zhang, Miaolei Shi, and Yang Liu. 2024. LLM4Vuln: A Unified Evaluation Framework for Decoupling and Enhancing LLMs’ Vulnerability Reasoning. *arXiv preprint arXiv:2401.16185* (2024).
- [38] Yuqiang Sun, Daoyuan Wu, Yue Xue, Han Liu, Haijun Wang, Zhengzi Xu, Xiaofei Xie, and Yang Liu. 2024. GPTScan: Detecting Logic Vulnerabilities in Smart Contracts by Combining GPT with Program Analysis. In *Proceedings of the IEEE/ACM 46th International Conference on Software Engineering (ICSE)*. ACM, New York, NY, USA, 2048–2060.
- [39] SunWeb3Sec. 2024. DeFiHackLabs: Reproduce DeFi hacked incidents using Foundry. <https://github.com/SunWeb3Sec/DeFiHackLabs>.

1277	[40]	Sergei Tikhomirov, Ekaterina Voskresenskaya, Ivan Ivanitskiy, Ramil Takhaviev, Evgeny Marchenko, and Yaroslav Alexandrov. 2018. SmartCheck: Static Analysis of Ethereum Smart Contracts. In <i>Proceedings of the 1st International Workshop on Emerging Trends in Software Engineering for Blockchain (WETSEB)</i> . IEEE, Piscataway, NJ, USA, 9–16.	1335
1278			
1279			
1280			
1281	[41]	Palina Tolmach, Yi Li, Shang-Wei Lin, Yang Liu, and Zengxiang Li. 2021. A Survey of Smart Contract Formal Specification and Verification. <i>Comput. Surveys</i> 54, 7 (2021), 1–38. doi:10.1145/3464421	1336
1282			
1283	[42]	Christof Ferreira Torres, Antonio Ken Iannillo, Arthur Gervais, and Radu State. 2021. ConFuzzius: A Data Dependency-Aware Hybrid Fuzzer for Smart Contracts. In <i>Proceedings of the IEEE European Symposium on Security and Privacy (EuroS&P)</i> . IEEE, Piscataway, NJ, USA, 103–119.	1337
1284			
1285			
1286	[43]	Petar Tsankov, Andrei Dan, Dana Drachler-Cohen, Arthur Gervais, Florian Bünzli, and Martin Vechev. 2018. Securify: Practical Security Analysis of Smart Contracts. In <i>Proceedings of the ACM SIGSAC Conference on Computer and Communications Security (CCS)</i> . ACM, New York, NY, USA, 67–82.	1338
1287			
1288			
1289			
1290			
1291			
1292			
1293			
1294			
1295			
1296			
1297			
1298			
1299			
1300			
1301			
1302			
1303			
1304			
1305			
1306			
1307			
1308			
1309			
1310			
1311			
1312			
1313			
1314			
1315			
1316			
1317			
1318			
1319			
1320			
1321			
1322			
1323			
1324			
1325			
1326			
1327			
1328			
1329			
1330			
1331			
1332			
1333			
1334			
	[44]	Fabian Vogelsteller and Vitalik Buterin. 2015. ERC-20: Token Standard. Ethereum Improvement Proposals, EIP-20. https://eips.ethereum.org/EIPS/eip-20 .	1339
	[45]	Sally Junsong Wang, Kexin Pei, and Junfeng Yang. 2024. SmartInv: Multimodal Learning for Smart Contract Invariant Inference. In <i>Proceedings of the IEEE Symposium on Security and Privacy (S&P)</i> . IEEE, Piscataway, NJ, USA, 2217–2235.	1340
	[46]	Fabian Yamaguchi, Nico Golde, Daniel Arp, and Konrad Rieck. 2014. Modeling and Discovering Vulnerabilities with Code Property Graphs. In <i>Proceedings of the IEEE Symposium on Security and Privacy (S&P)</i> . IEEE, Piscataway, NJ, USA, 590–604.	1341
	[47]	Liyi Zhou, Xihan Xiong, Jens Ernstberger, Stefanos Chaliasos, Zhipeng Wang, Ye Wang, Kaihua Qin, Roger Wattenhofer, Dawn Song, and Arthur Gervais. 2023. SoK: Decentralized Finance (DeFi) Attacks. In <i>Proceedings of the IEEE Symposium on Security and Privacy (S&P)</i> . IEEE, Piscataway, NJ, USA, 2444–2461.	1342
			1343
			1344
			1345
			1346
			1347
			1348
			1349
			1350
			1351
			1352
			1353
			1354
			1355
			1356
			1357
			1358
			1359
			1360
			1361
			1362
			1363
			1364
			1365
			1366
			1367
			1368
			1369
			1370
			1371
			1372
			1373
			1374
			1375
			1376
			1377
			1378
			1379
			1380
			1381
			1382
			1383
			1384
			1385
			1386
			1387
			1388
			1389
			1390
			1391
			1392